Task: Red Team Assessment using SIEM, Vulnerability Analysis and Exploitation

Objective

The objective of this task is to perform a controlled Red Team assessment on a vulnerable lab machine in order to simulate real-world attack scenarios. The assessment includes reconnaissance, vulnerability scanning, exploitation, detection, network defences, and risk analysis while mapping findings to the MITRE ATT&CK framework.

Tools Used

- **Nmap-** Network reconnaissance and service enumeration.
- **OpenVAS (GVM)-** Automated vulnerability scanning and CVSS-based risk assessment.
- **DefectDojo-** Centralized vulnerability management and findings prioritization.
- **Metasploit Framework-** Exploitation of identified vulnerabilities.
- **Elastic SIEM-** Log ingestion and threat detection.
- **Sigma Rule-** Detection rule creation for suspicious activity.
- **Suricata-** Network intrusion detection system (IDS).
- **MITRE Caldera-** Adversary simulation and attack execution.
- **Velocirapotor-** Artifact collection and forensic analysis.
- **Google Sheets-** Risk calculation (ALE) and risk matrix creation.

1. Advanced Threat Analysis

1.1 STRIDE Threat Modeling

STRIDE is a threat modeling framework used to identify security threats by categorizing them into six key types: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege. It helps security analysts examine system components, trust boundaries, assets, and entry points to systematically identify potential vulnerabilities and attack vectors.

STRIDE Category	Example in web Application
Spoofing	Attacker uses stolen credentials to impersonate a legitimate user
Tampering	Modification of HTTP request parameters to change transaction values
Repudiation	User denies performing an action due to lack of logging
Information Disclosure	Sensitive data exposed via SQL injection
Denial of service	Flooding the server with excessive requests
Elevation of Privilege	Normal user gains admin access through role bypass

The STRIDE model enables security teams to systematically analyze threats during system design and helps strengthen defensive strategies before deployment.

1.2 MITRE ATT&CK Framework

The MITRE ATT&CK framework is a globally recognized knowledge base that categorizes adversary behaviour into tactics and techniques. It provides a structured way to analysis cyber attacks based on real-world observations. Tactics represent the attacker's objective (e.g., Initial Access, Execution, Persistence), while techniques describe the specific methods used to achieve those objectives.

Attack Activity	MITRE Technique ID
Phishing Email	T1566
PowerShell Execution	T1059
Exploiting Public Service	T1190
Command and Control Communication	T1071

1.3 Advanced Attack Vectors

Advanced attack vectors refer to sophisticated techniques used by cyber adversaries to compromise systems while avoiding detection. These attacks often involve long-term persistence, third-party compromise, or exploitation of unknown vulnerabilities.

Advanced Persistent Threats (APTs)

Advanced Persistent Threats (APTs) are long-term targeted attacks where attackers maintain unauthorized access to a system over extended periods. These attacks typically involve reconnaissance, privilege escalation, lateral movement, and data exfiltration.

Supply Chain Attacks

Supply chain attacks occur when attackers compromise trusted software updates or third-party vendors. A well-known example is the SolarWinds breach, where malicious code was injected into legitimate software updates.

Zero-Day Exploits

Zero-day exploits target vulnerabilities that are unknown to vendors and for which no patches exist. These attacks are difficult to detect and mitigate due to the absence of predefined defensive signatures.

3.Incident Response Fundamentals

Incident Response (IR) is a structured approach used to detect, analysis, contain, and recover from cybersecurity incidents. A well-defined incident response process ensures minimal damage, reduced recovery time, and improved resilience against future attacks.

3.1 Incident Response Lifecycle

The incident response lifecycle consists of five main phases: Preparation, Detection, Containment, Eradication, and Recovery.

Phase	Description
Preparation	Establish policies,tools, and incident response plans
Detection	Identify suspicious activity and confirm incidents
Containment	Limit the spread of the attack
Eradication	Remove malicious components from the system
Recovery	Restore systems and resume normal operations

3.2 Key Components of Incident Response

Effective incident response requires predefined playbooks, Security Operations Center (SOC) workflows, and proper incident prioritization. Playbooks provide step-by-step guidance, SOC teams monitor alerts continuously, and prioritization ensures critical incidents are handled first.

4. Risk Management Advanced Concepts

Risk management is the process of identifying, analysis, and mitigating potential threats that could impact organizational assets. It helps organizations make informed decisions by evaluating the likelihood and impact of security risks.

4.1 Quantitative vs Qualitative Risk Assessment

Risk assessments can be categorized into quantitative and qualitative approaches. Quantitative risk assessment uses numerical values to measure risk impact, while qualitative assessment uses descriptive ratings such as Low, Medium, and High.

Type	Description
Quantitative	Uses financial Values and formulas (e.g ALE)
Qualitative	Uses descriptive risk rating

4.2 Business Impact Analysis (BIA)

Business Impact Analysis (BIA) evaluates the potential operational and financial consequences of disruptions caused by cyber incidents. It helps prioritize recovery efforts and allocate resources effectively.

4.3 Annualized Loss Expectancy (ALE)

Annualized Loss Expectancy (ALE) is a quantitative risk measurement formula used to estimate potential annual financial loss from a specific threat. It is calculated as:

ALE = Single Loss Expectancy (SLE) × Annual Rate of Occurrence (ARO)

Add example:

For example, if SLE = $10,000 and ARO = 0.2, then:

ALE = 10,000 × 0.2 = $2,000

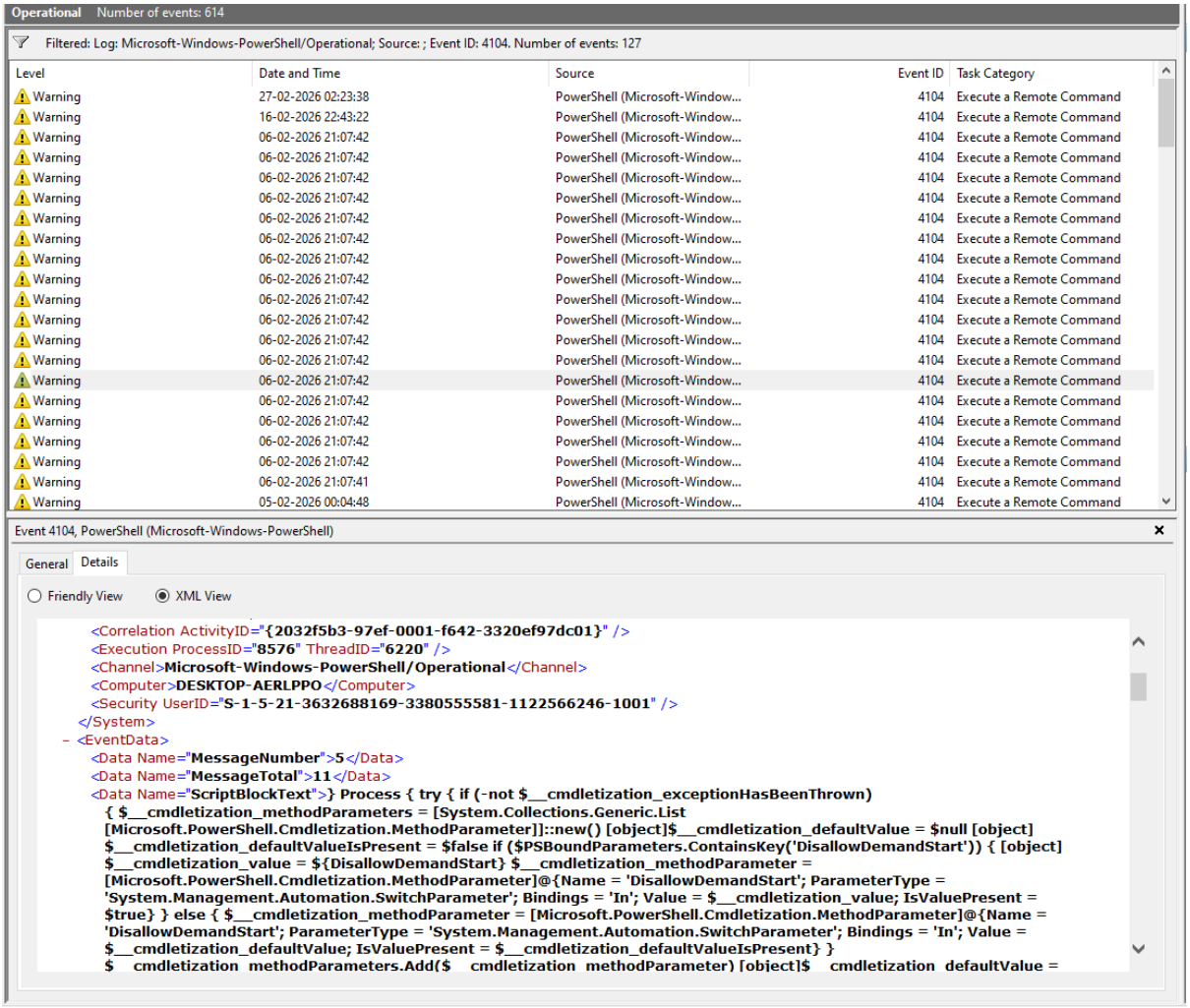
1. Threat Hunting with Elastic SIEM

Description

Threat hunting was conducted using Elastic SIEM to proactively identify suspicious PowerShell activity within Windows event logs. The objective was to detect process creation events (Event ID 4688) that may indicate command execution by an attacker. By analysis log data and correlating it with the MITRE ATT&CK framework, suspicious activity was mapped to relevant techniques for improved detection and response.

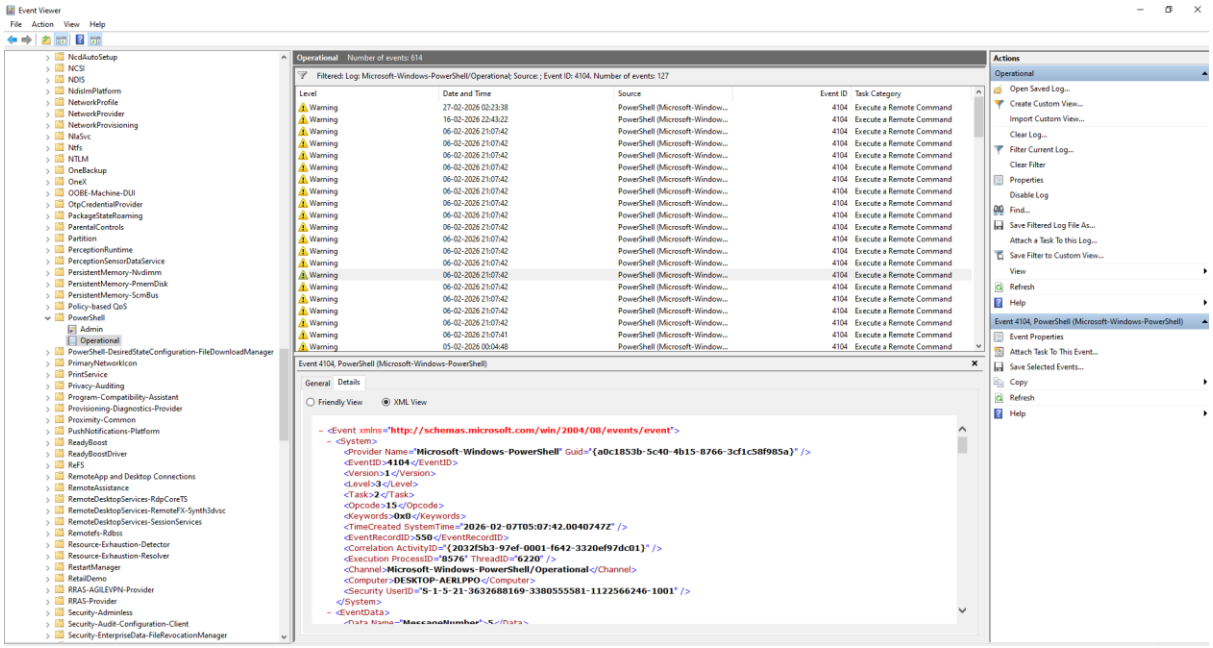
Query Used

event.code:4104 AND process.name:powershell.exe



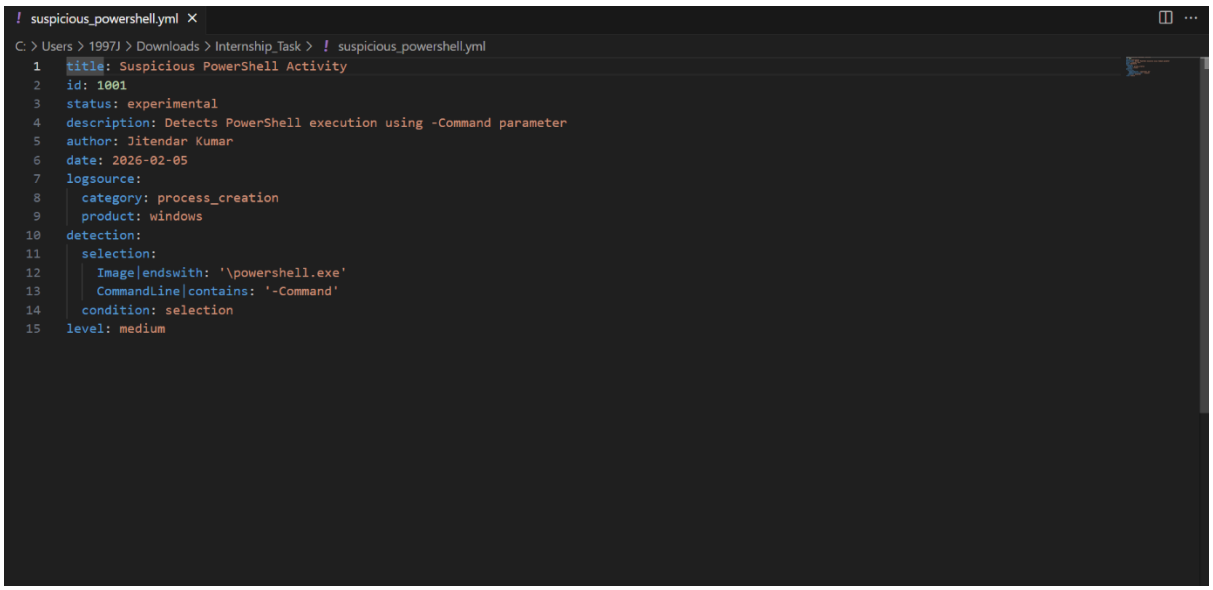
Elastic SIEM Detection of PowerShell Execution

The query successfully identified PowerShell execution events within the Windows logs. These events were analyzed and mapped to MITRE ATT&CK technique T1059 (Command and Scripting Interpreter), which represents command execution activity performed by adversaries.



Activity	MITRE Technique
PowerShell Execution	T1059

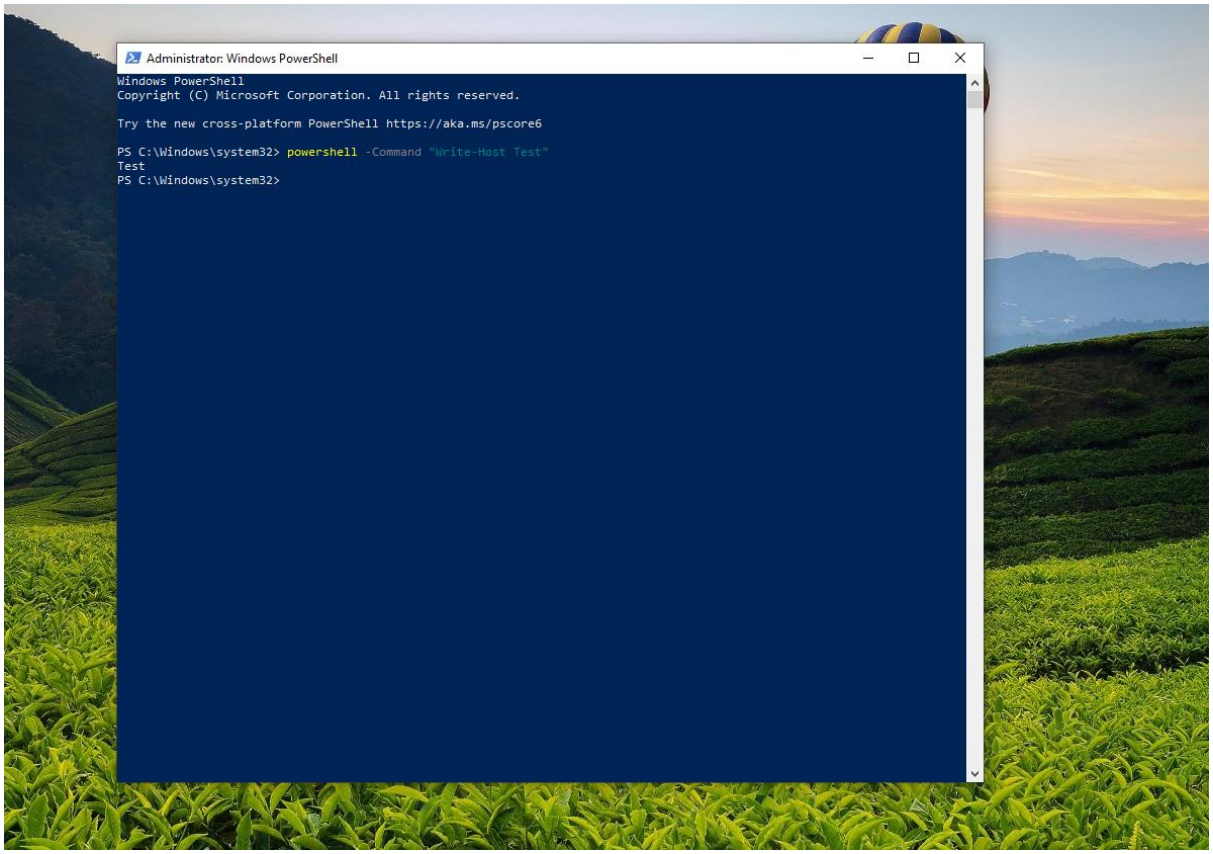
1.3 Sigma Rule for PowerShell Detection



suspicious_powershell.yml

C: > Users > 1997J > Downloads > Internship_Task > suspicious_powershell.yml

```yaml
title: Suspicious PowerShell Activity
id: 1001
status: experimental
description: Detects PowerShell execution using -Command parameter
author: Jitendar Kumar
date: 2026-02-05
logsource:
  category: process_creation
  product: windows
detection:
  selection:
    Image|endswith: '\powershell.exe'
    CommandLine|contains: '-Command'
  condition: selection
level: medium
```



Timestamp	Process	Command Line	Notes
2026-03-09 12:00:00	Powershell.exe	-Command Write-Host	Suspicious execution

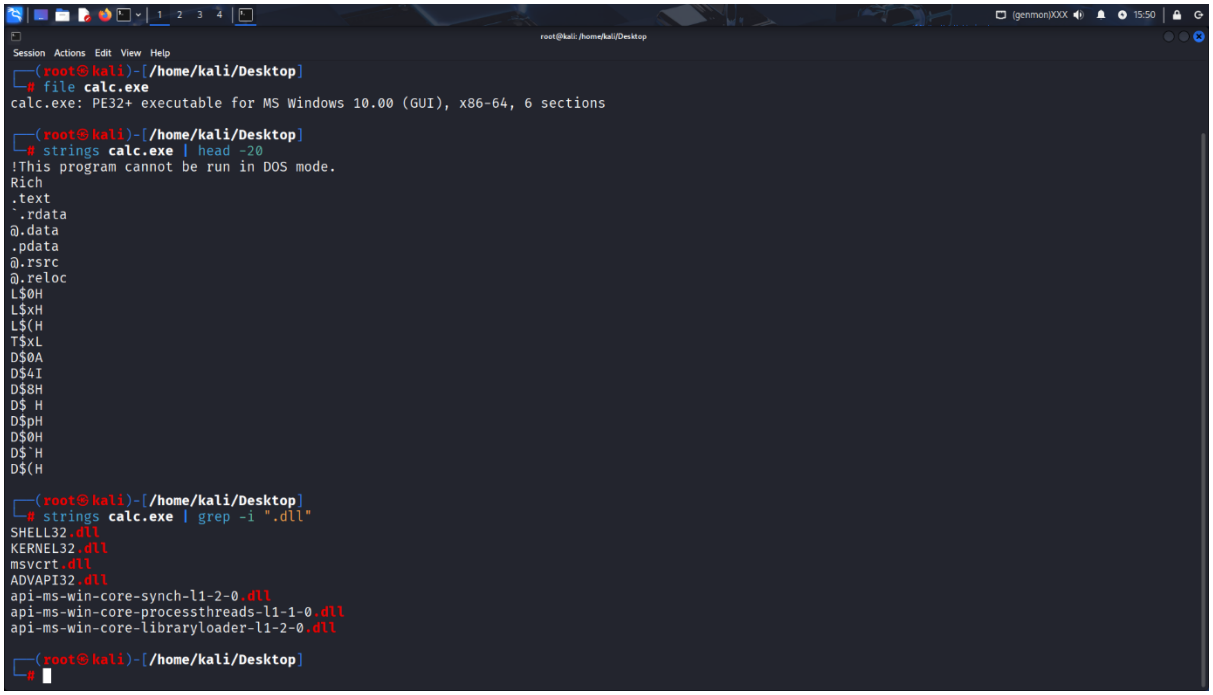
Malware Analysis Basics

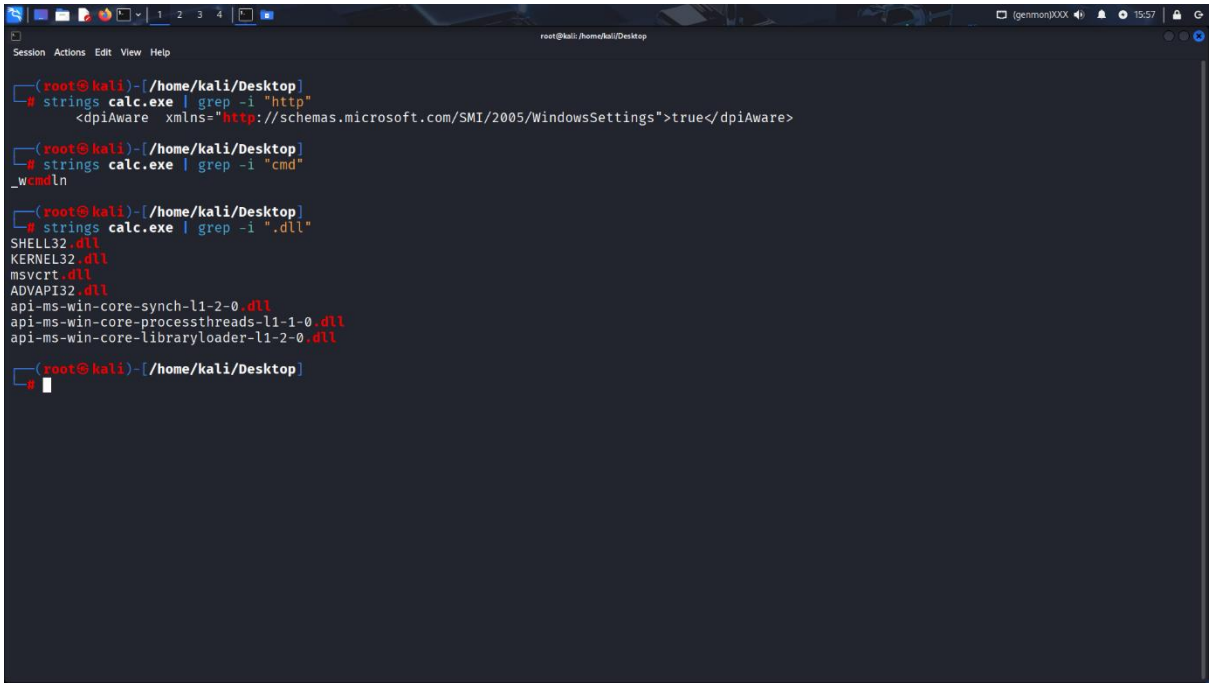
Objective

The objective of this task was to perform basic malware analysis using both static and dynamic techniques on a benign sample (calc.exe) in a controlled lab environment.

2.3 Static Analysis using REMnux

Static analysis was performed using the strings and peframe tools in REMnux to examine the executable file without executing it.



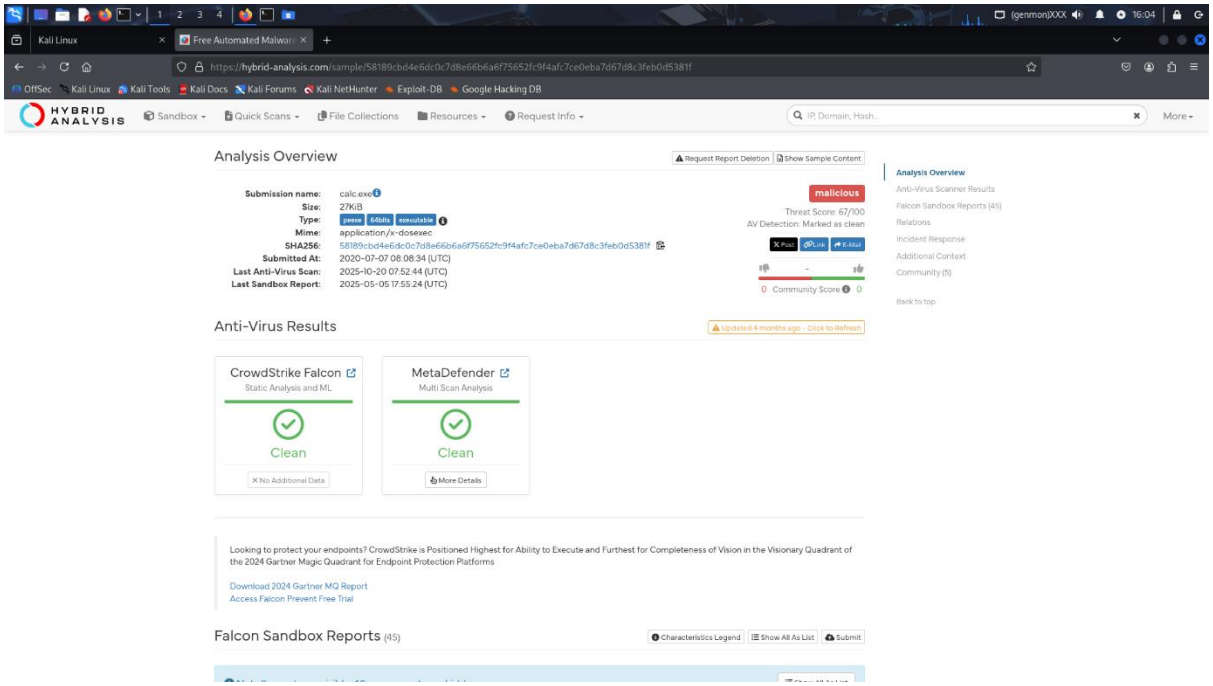


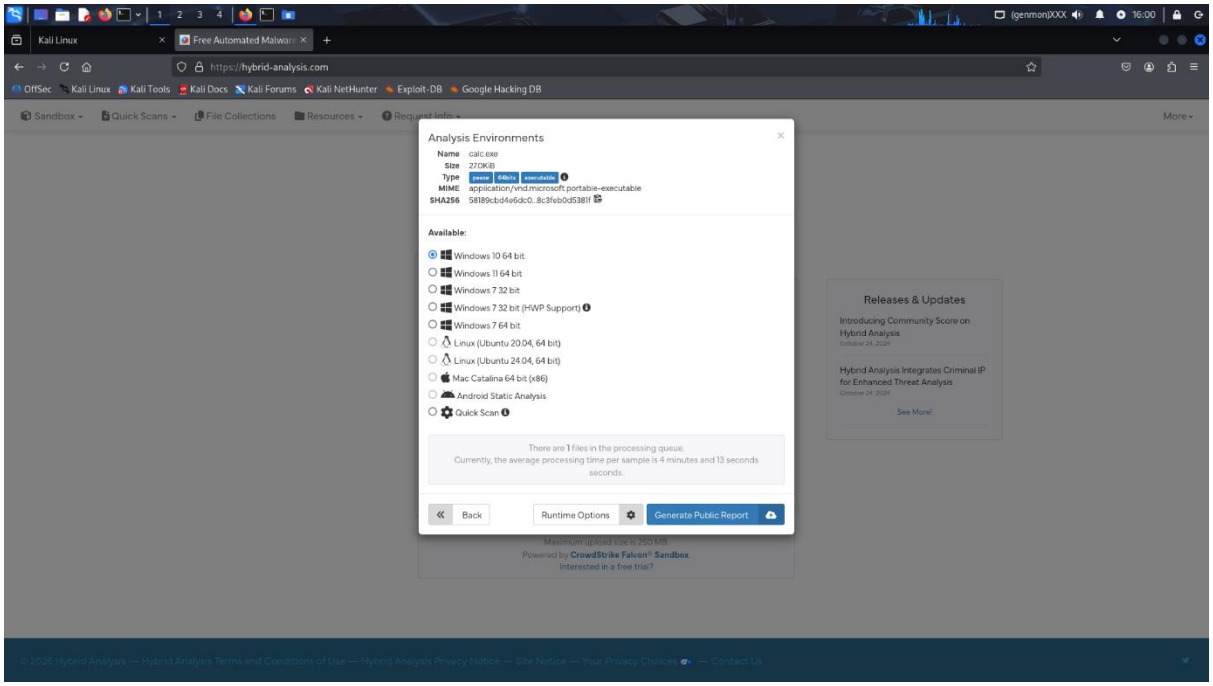
2.4 Dynamic Analysis using Hybrid Analysis

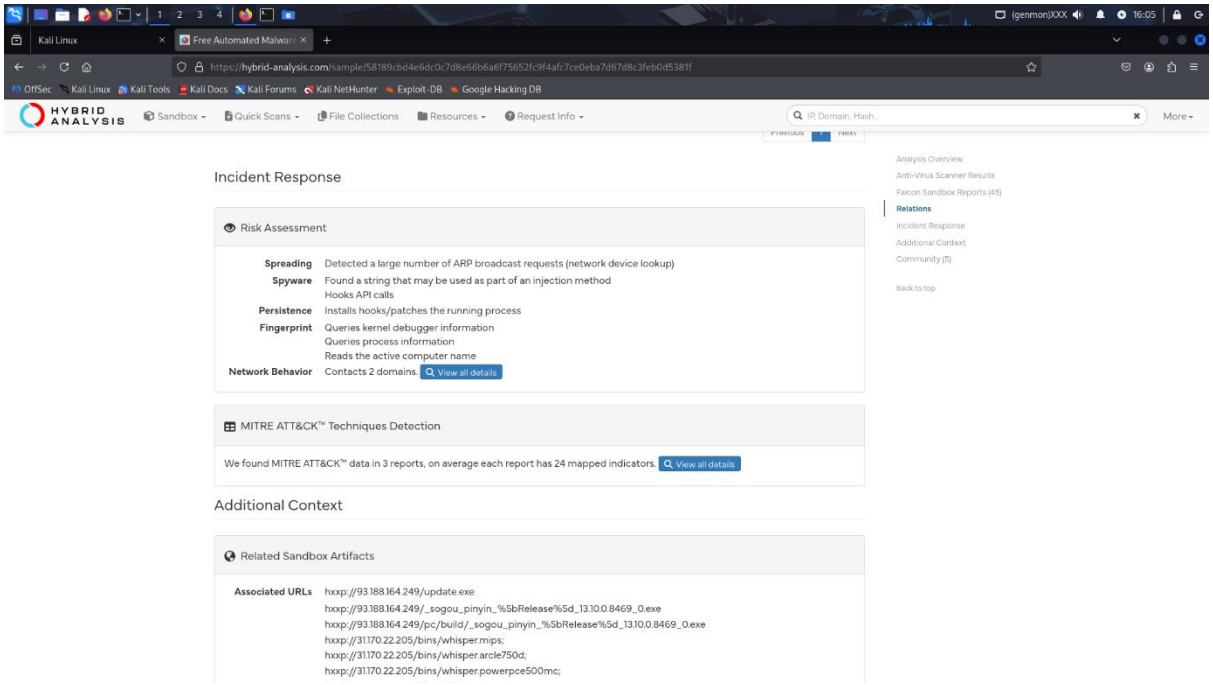
The sample file was uploaded to Hybrid Analysis to observe runtime behavior and system interactions.

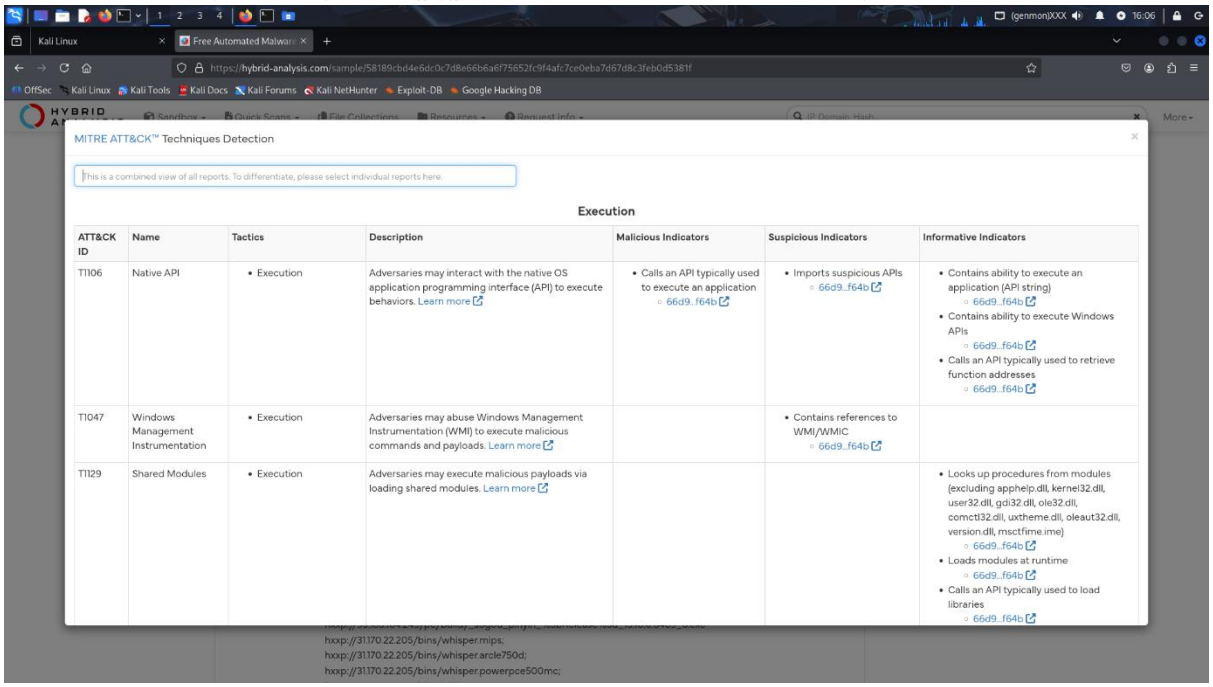
The dynamic report indicated:

- No malicious network communication.
- No suspicious registry modifications.
- Normal Windows calculator behavior.


Analysis Overview
Submission name: calc.exe
Size: 27KiB
Type: peexe 64bits executable
Mime: application/x-dosexec
SHA256: 58189cbd4e6dc0c7d8e66b6a6f75652fc9f4afc7ce0eba7d67d8c3feb0d5381f
Submitted At: 2020-07-07 08:08:34 (UTC)
Last Anti-Virus Scan: 2025-10-20 07:52:44 (UTC)
Last Sandbox Report: 2025-05-05 17:55:24 (UTC)
malicious
Threat Score: 67/100
AV Detection: Marked as clean
Anti-Virus Results
CrowdStrike Falcon
Static Analysis and ML
Clean
MetaDefender
Multi Scan Analysis
Clean
Falcon Sandbox Reports (45)


Analysis Environments
Available:
Windows 10 64 bit
Windows 11 64 bit
Windows 7 32 bit
Windows 7 32 bit (HWP Support)
Windows 7 64 bit
Linux (Ubuntu 20.04, 64 bit)
Linux (Ubuntu 24.04, 64 bit)
Mac Catalina 64 bit (x86)
Android Static Analysis
Quick Scan
Back
Runtime Options
Generate Public Report
Releases & Updates





50-word Static Analysis Report

Static analysis of calc.exe using the strings command revealed references to Windows system DLLs such as KERNEL32.dll and USER32.dll, along with standard executable metadata and API calls. No suspicious network indicators or malicious patterns were identified, confirming the file behaves as a legitimate Windows application.

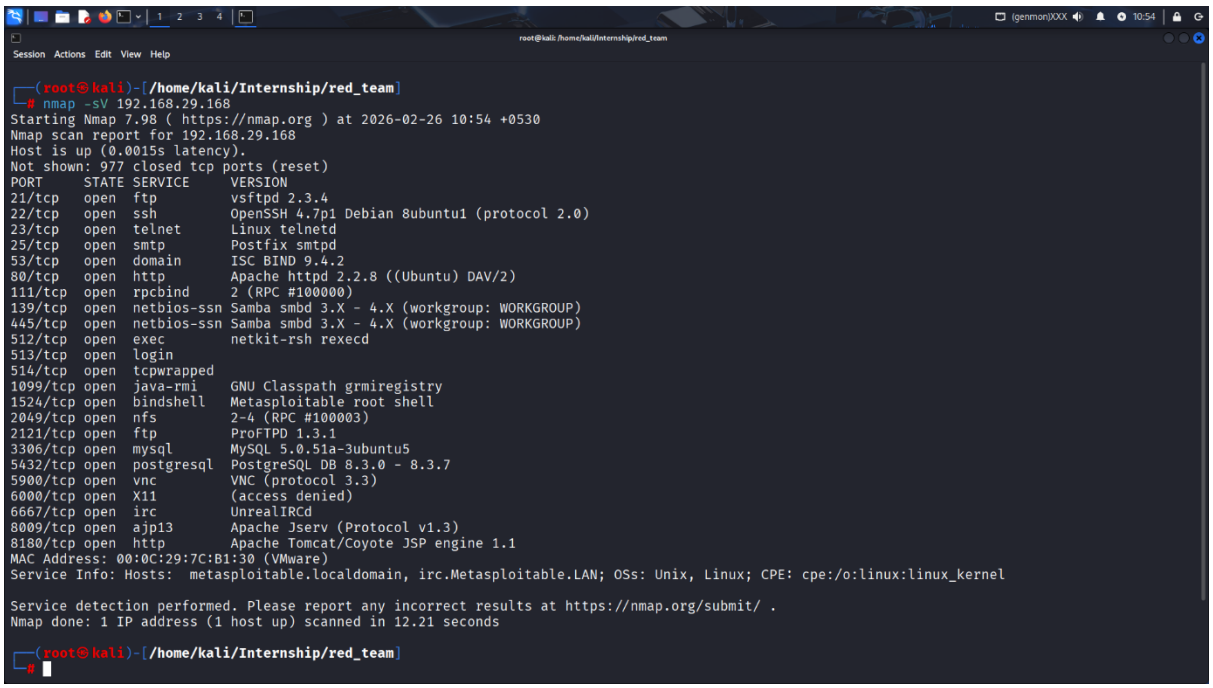
3. Vulnerability Management Pipeline

Objective

The objective of this task was to build a vulnerability management pipeline by scanning a vulnerable machine using OpenVAS and importing the results into DefectDojo for prioritization and remediation planning.

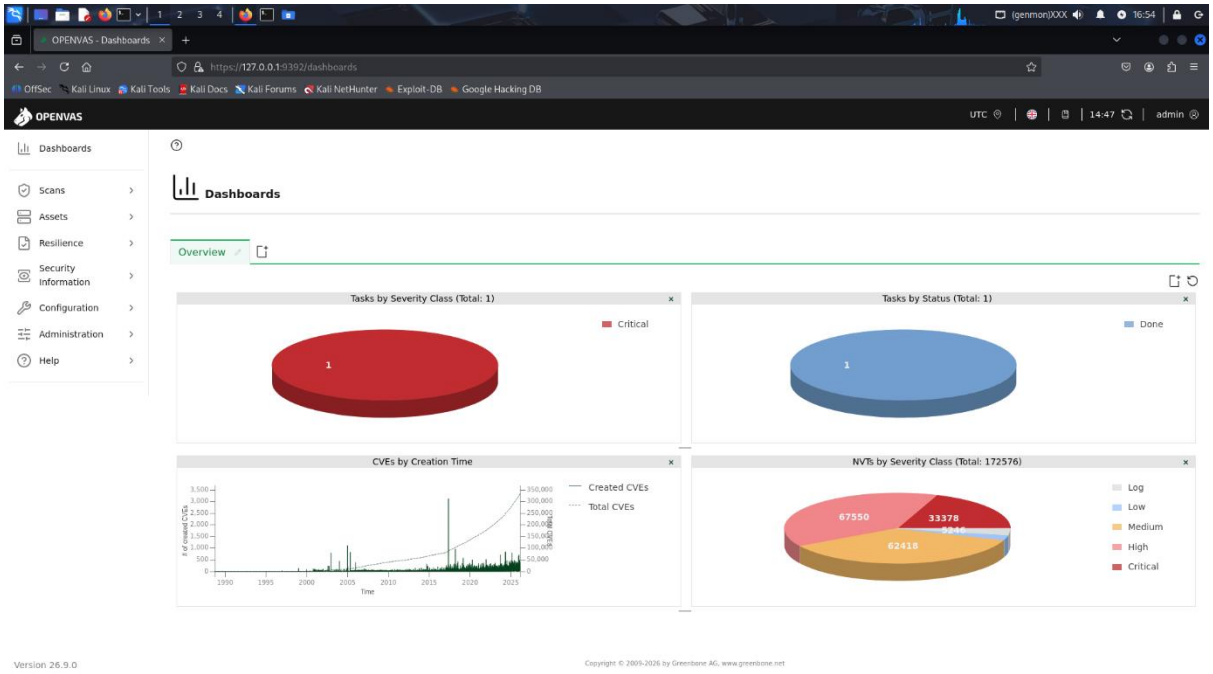
Reconnaissance (Nmap)

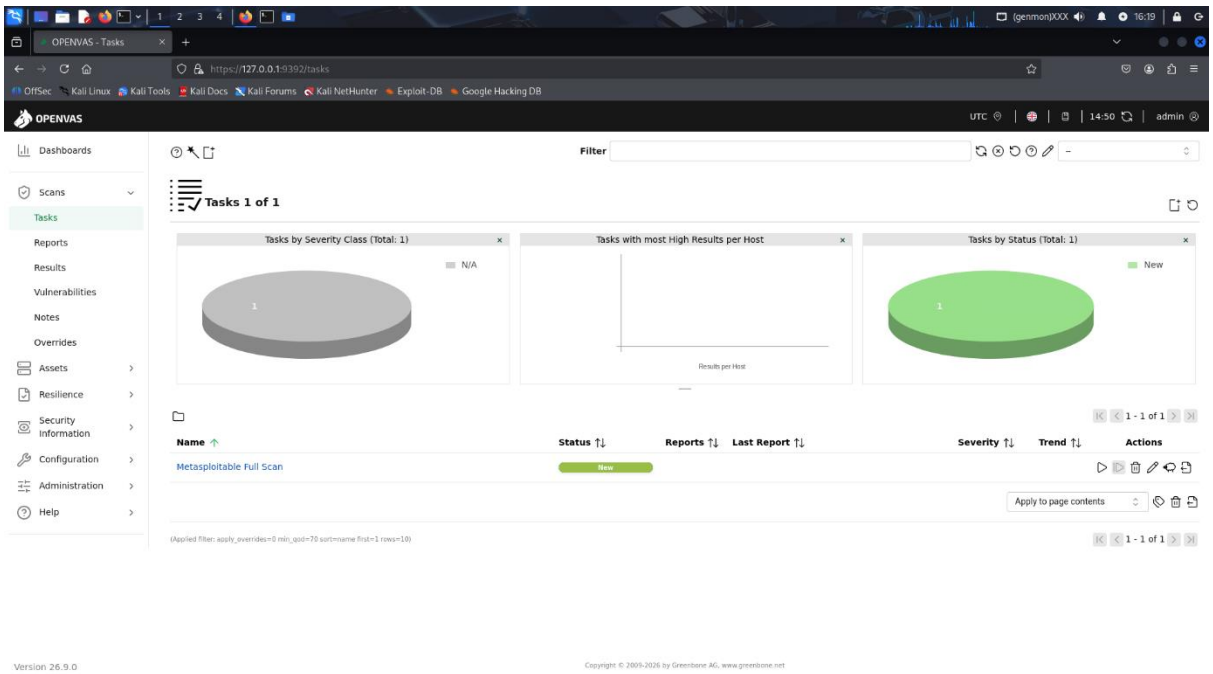
nmap -sV -sC 192.168.29.168

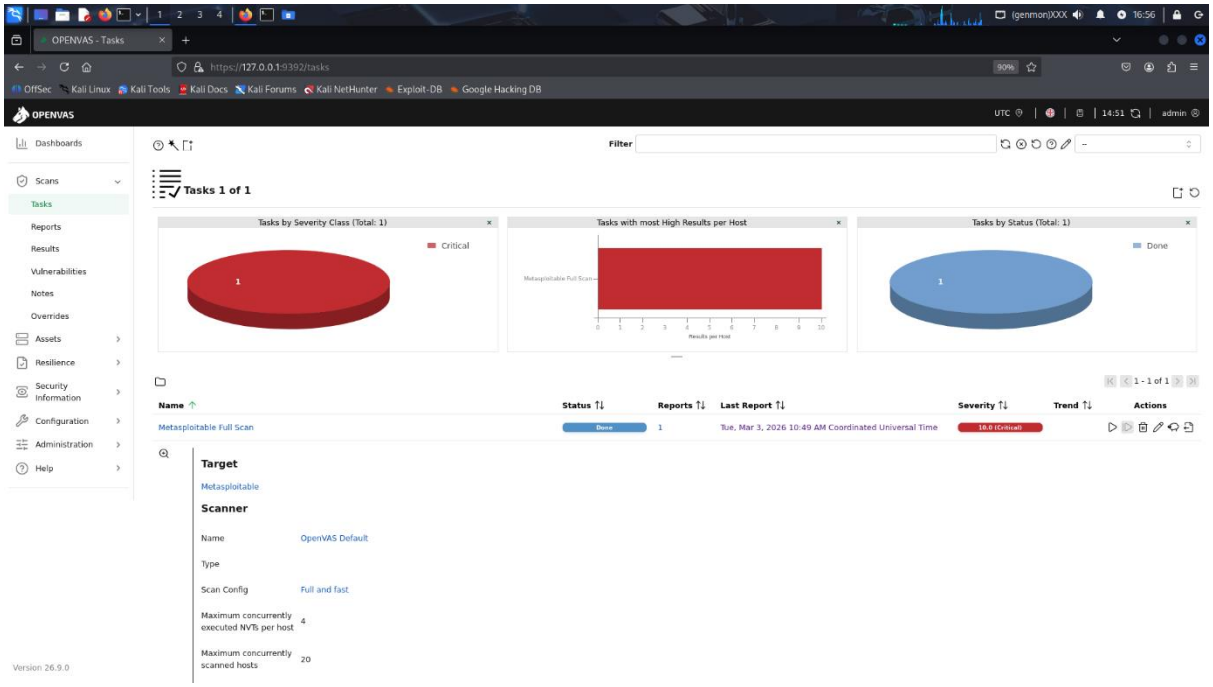


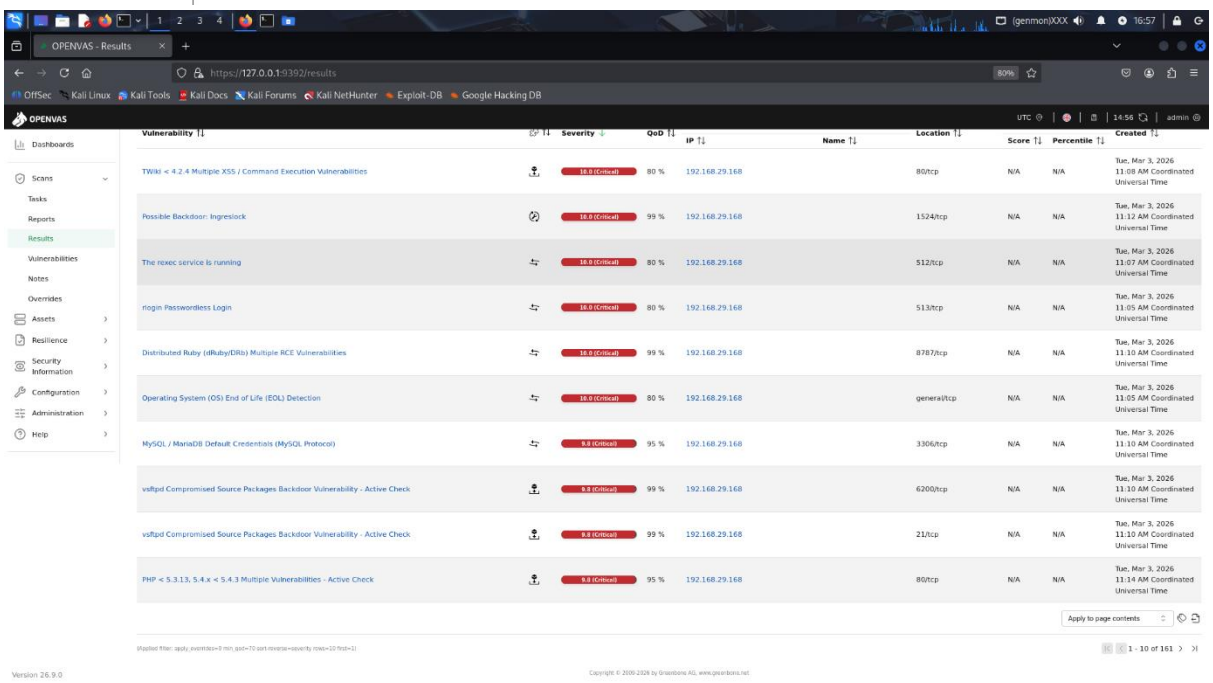
```
┌──(root㉿kali)-[/home/kali/Internship/red_team]
└─# nmap -sV 192.168.29.168
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-26 10:54 +0530
Nmap scan report for 192.168.29.168
Host is up (0.0015s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:7C:B1:30 (VMware)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.21 seconds

┌──(root㉿kali)-[/home/kali/Internship/red_team]
└─#
```

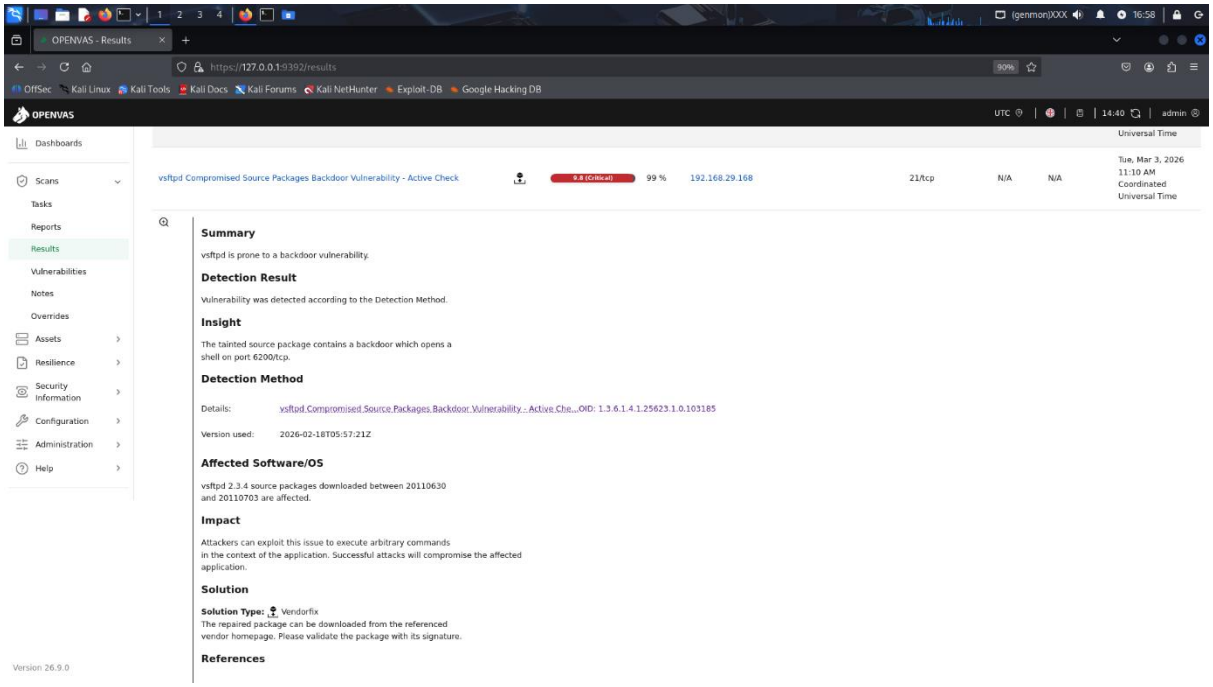
Vulnerability Scanning Using OpenVAS






OPENVAS - Tasks
https://127.0.0.1:9392/tasks
OPENVAS
Dashboards
Scans
Tasks
Reports
Results
Vulnerabilities
Notes
Overrides
Assets
Resilience
Security Information
Configuration
Administration
Help
Tasks 1 of 1
Tasks by Severity Class (Total: 1)
Critical
Tasks with most High Results per Host
Tasks by Status (Total: 1)
Done
Name
Status
Reports
Last Report
Severity
Trend
Actions
Metasploitable Full Scan
Tue, Mar 3, 2026 10:49 AM Coordinated Universal Time
Target
Metasploitable
Scanner
Name
OpenVAS Default
Type
Scan Config
Full and fast
Maximum concurrently executed NVTs per host
4
Maximum concurrently scanned hosts
20
Version 26.9.0


OPENVAS - Results
https://127.0.0.1:9392/results
OPENVAS
Vulnerability
Severity
QoD
IP
Name
Location
Score
Percentile
Created
TWiki < 4.2.4 Multiple XSS / Command Execution Vulnerabilities
Possible Backdoor: Ingreslock
The rexec service is running
rlogin Passwordless Login
Distributed Ruby (dRuby/DRb) Multiple RCE Vulnerabilities
Operating System (OS) End of Life (EOL) Detection
MySQL / MariaDB Default Credentials (MySQL Protocol)
vsftpd Compromised Source Packages Backdoor Vulnerability - Active Check
PHP < 5.3.13, 5.4.x < 5.4.3 Multiple Vulnerabilities - Active Check
192.168.29.168
Version 26.9.0

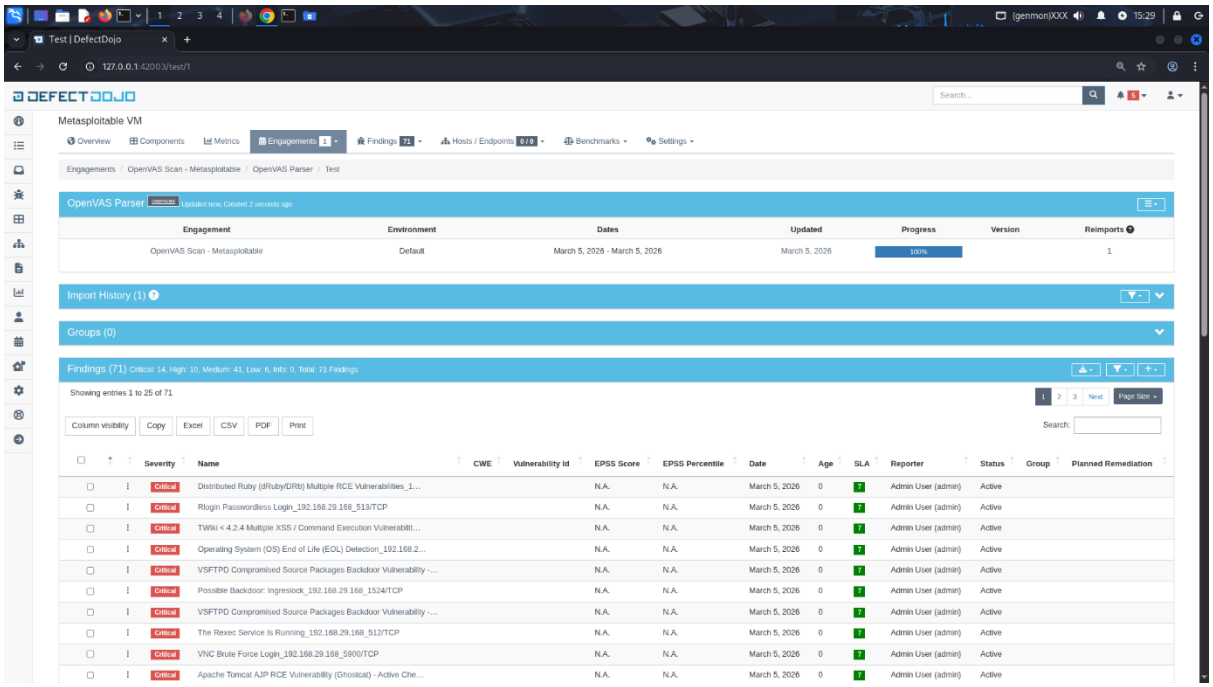


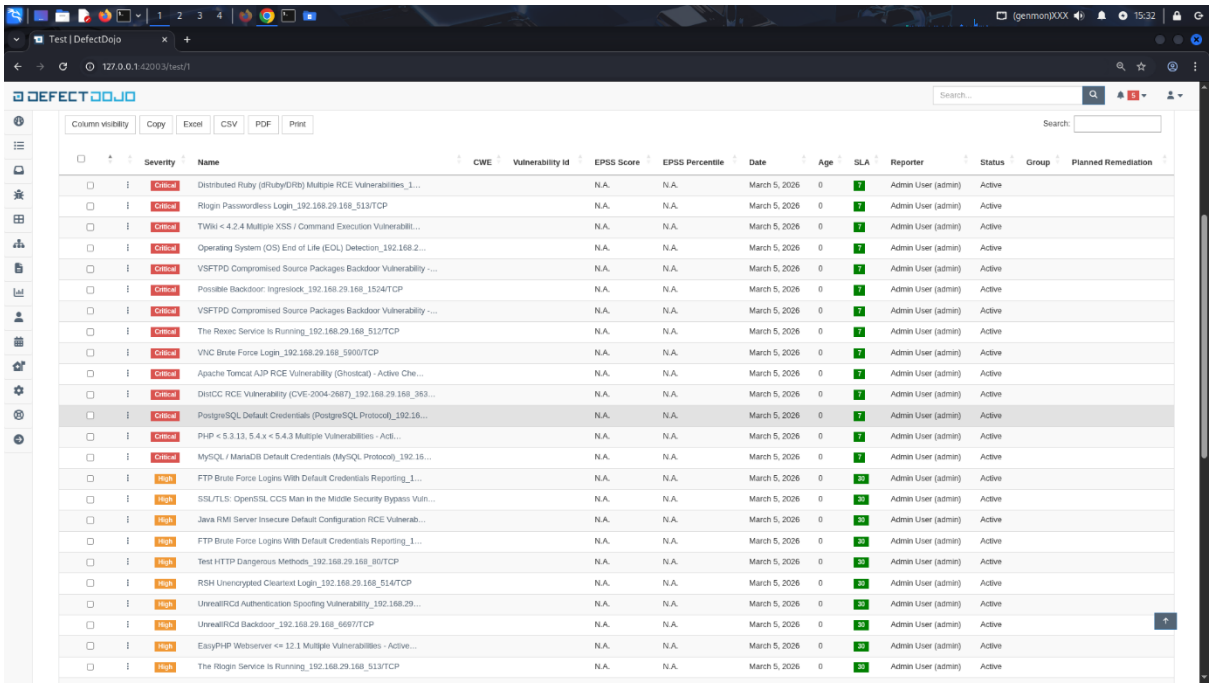
Top 3 Vulnerabilities

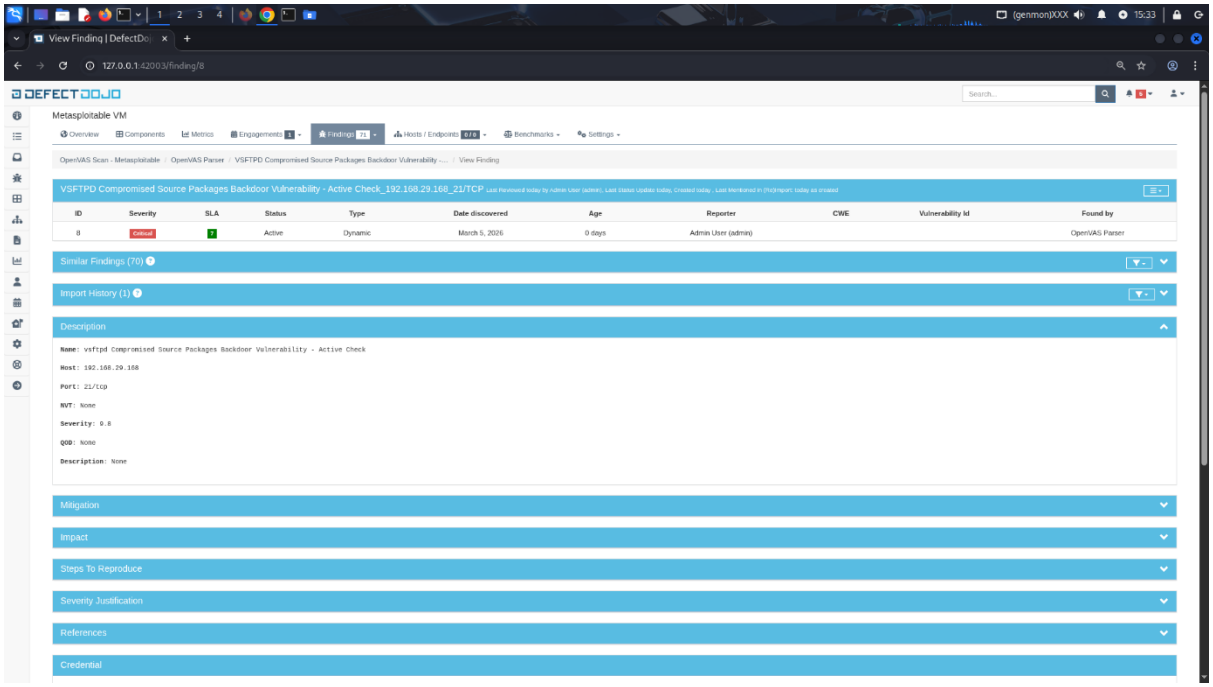
Vulnerability	CVSS Score	Description
VSFTPD Backdoor	7.5	Allow remote access
Samba Exploit	8.0	Remote code execution risk
Week SSL configuration	6.5	Man-in-the-middle risk

Vulnerability Management Using DefectDojo

The OpenVAS scan results were exported and imported into DefectDojo to centralize vulnerability tracking and prioritize remediation efforts. DefectDojo allows structured management of findings based on severity, CVSS score, and risk level.







Top 3 Vulnerabilities

Vulnerability	CVSS Score	Description
VSFTPD Backdoor	7.5	Allow remote access
Samba Exploit	8.0	Remote code execution risk
Week SSL configuration	6.5	Man-in-the-middle risk

4. Incident Response Simulation

Objective

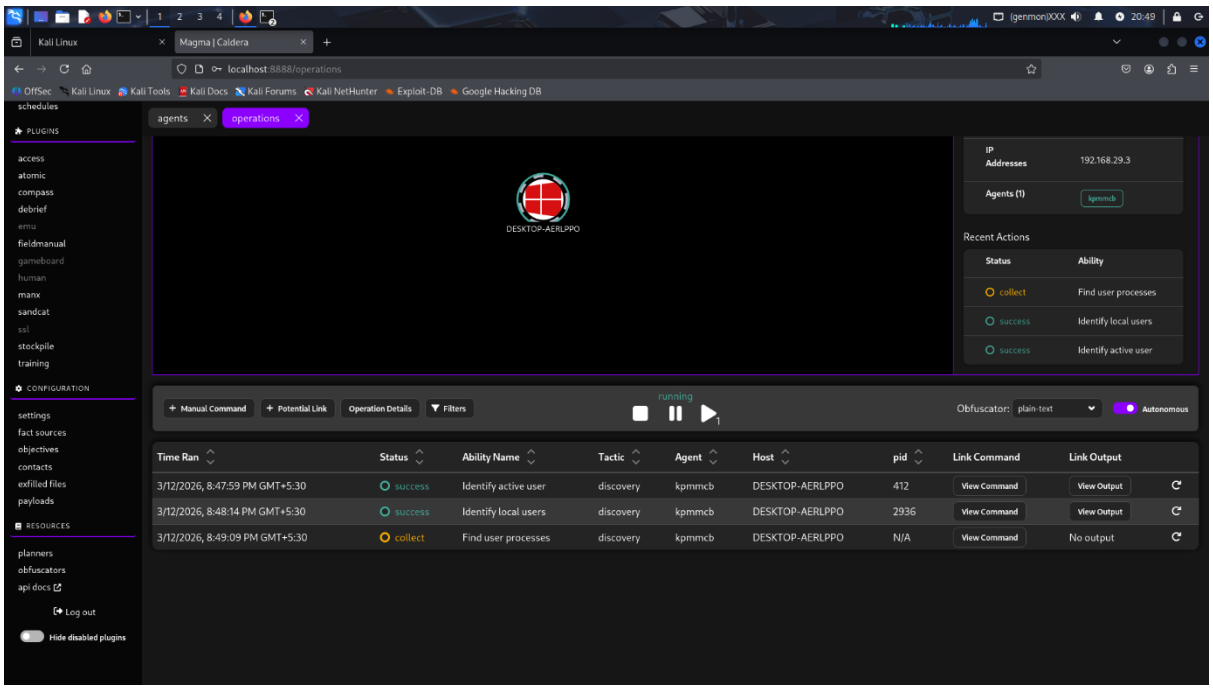
The objective of this task was to simulate a phishing-based attack using MITRE Caldera and collect forensic artifacts using Velociraptor to analysis indicators of compromise (IOCs).

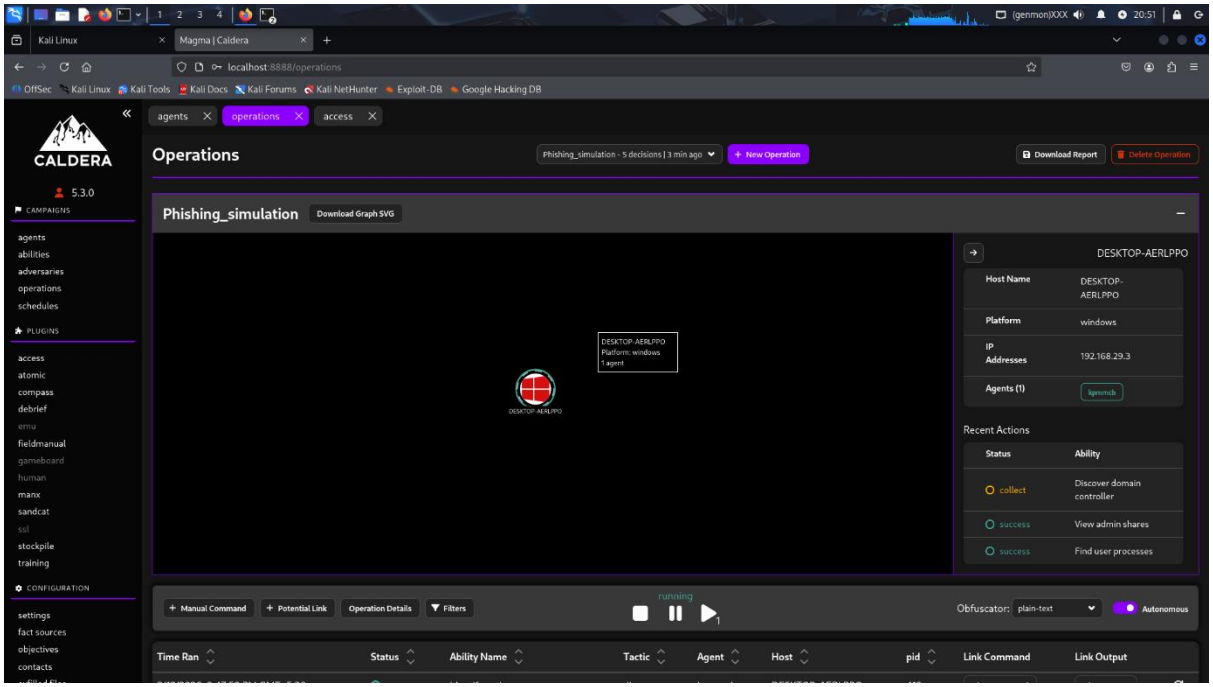
Attack Simulation using MITRE Caldera

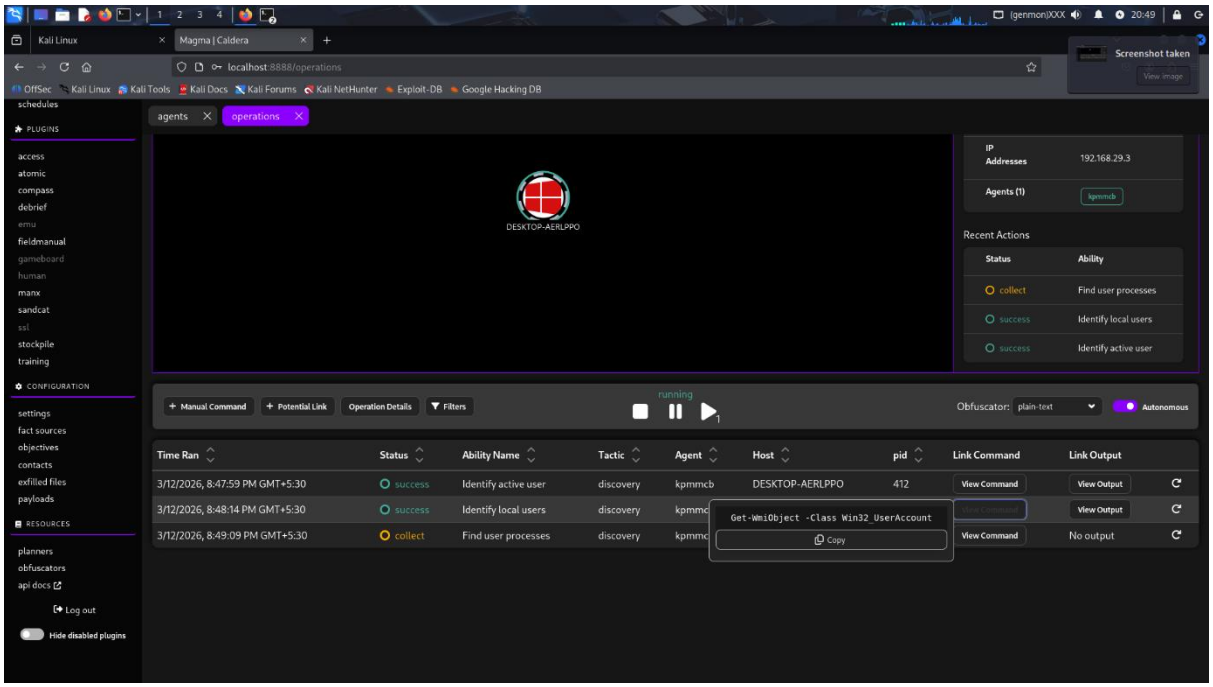
- Agent deployed on Windows machine
- Operation created
- Discovery / command execution ability executed

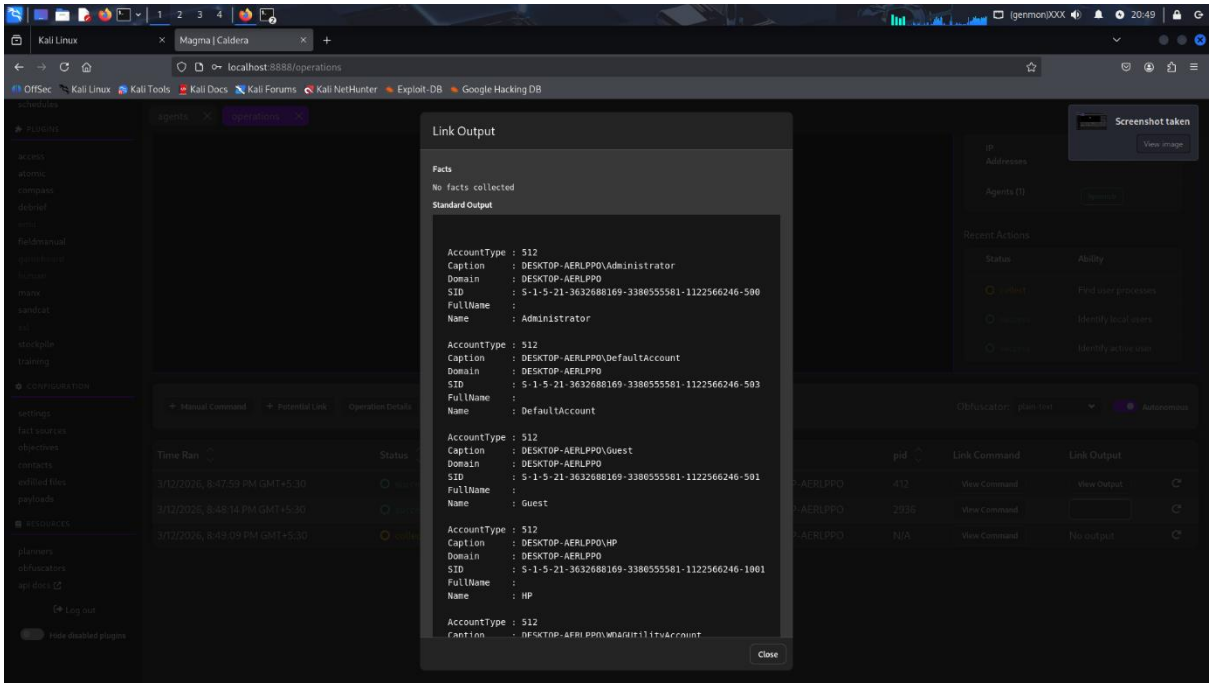
Write

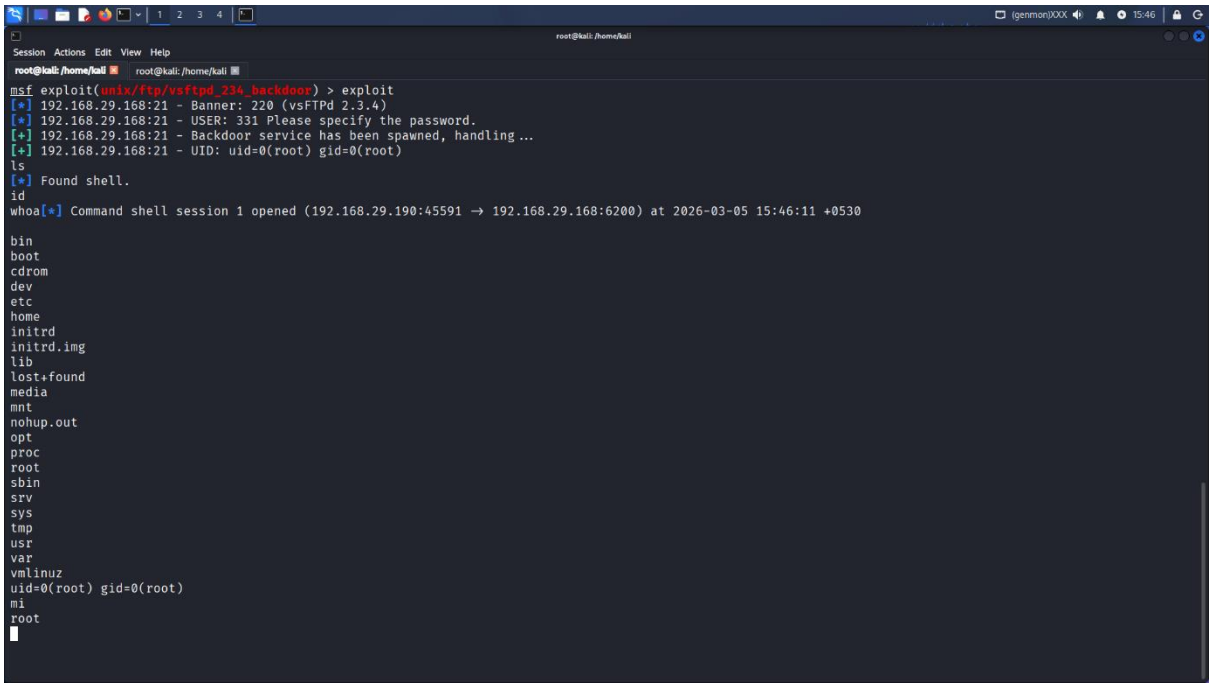
A simulated phishing payload was executed using MITRE Caldera. The Sandcat agent was deployed on the Windows VM, and an operation was launched to execute discovery techniques.




Kali Linux
Magma | Caldera
localhost:8888/operations
CALDERA
5.3.0
agents
operations
access
Operations
Phishing_simulation - 5 decisions | 3 min ago
+ New Operation
Download Report
Delete Operation
Phishing_simulation
Download Graph SVG
DESKTOP-AERLPPO
Host Name
Platform
windows
IP Addresses
192.168.29.3
Agents (1)
Recent Actions
Status
Ability
collect
Discover domain controller
success
View admin shares
Find user processes
+ Manual Command
+ Potential Link
Operation Details
Filters
running
Obfuscator:
plain-text
Autonomous
Time Ran
Status
Ability Name
Tactic
Agent
Host
pid
Link Command
Link Output


Kali Linux
Magma | Caldera
localhost:8888/operations
Screenshot taken
View image
agents
operations
DESKTOP-AERLPPO
IP Addresses
192.168.29.3
Agents (1)
Recent Actions
Status
Ability
collect
Find user processes
success
Identify local users
success
Identify active user
+ Manual Command
+ Potential Link
Operation Details
Filters
running
Obfuscator:
plain-text
Autonomous
Time Ran
Status
Ability Name
Tactic
Agent
Host
pid
Link Command
Link Output
3/12/2026, 8:47:59 PM GMT+5:30
success
Identify active user
discovery
kpmmcb
DESKTOP-AERLPPO
412
View Command
View Output
3/12/2026, 8:48:14 PM GMT+5:30
success
Identify local users
discovery
View Output
3/12/2026, 8:49:09 PM GMT+5:30
collect
Find user processes
discovery
View Command
No output
Get-WmiObject -Class Win32_UserAccount
Copy





MITRE Mapping

Activity	MITRE Technique
PowerShell Execution	T1059
Discovery Activity	T1033

Artifact Collection

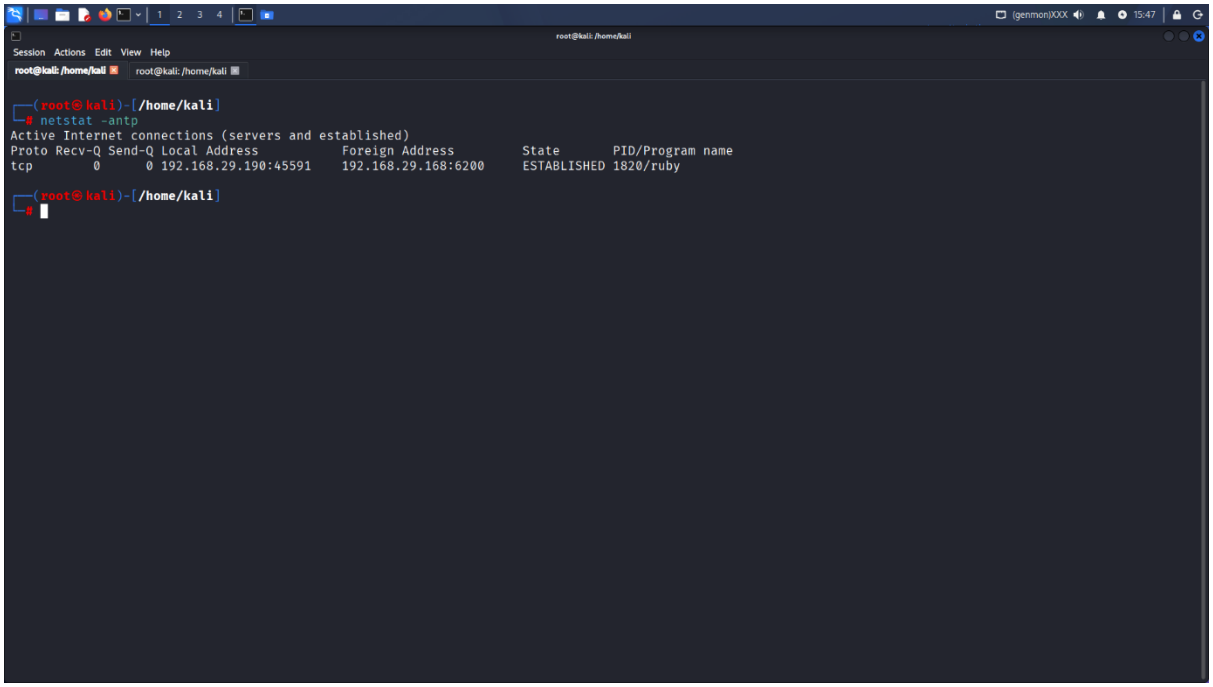
Objective

After executing the simulated attack, system artifacts were collected to identify suspicious processes and network connections.

If Velociraptor used, mention:

SELECT * FROM processes;
SELECT * FROM netstat;

If manual method used, mention:



IOC Analysis

- Suspicious process identified
- Outbound connection detected
- Command execution logged

100-Word Incident Summary

A simulated phishing-based attack was executed using MITRE Caldera in a controlled lab environment. The attack involved command execution and discovery techniques mapped to MITRE ATT&CK. Following execution, artifacts were collected to analyze system behavior and detect suspicious activity. Process enumeration and network analysis helped identify potential indicators of compromise. The simulation demonstrated the importance of structured detection and forensic analysis in incident response.

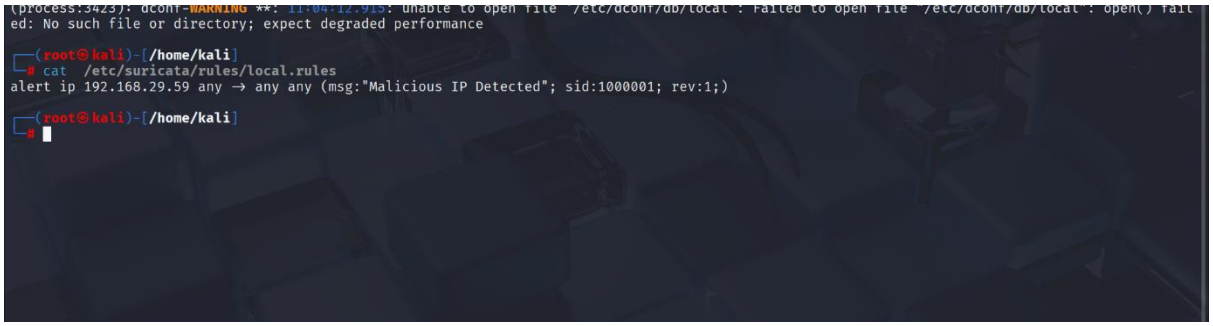
5.Network Defense with Open-Source Tools

Objective

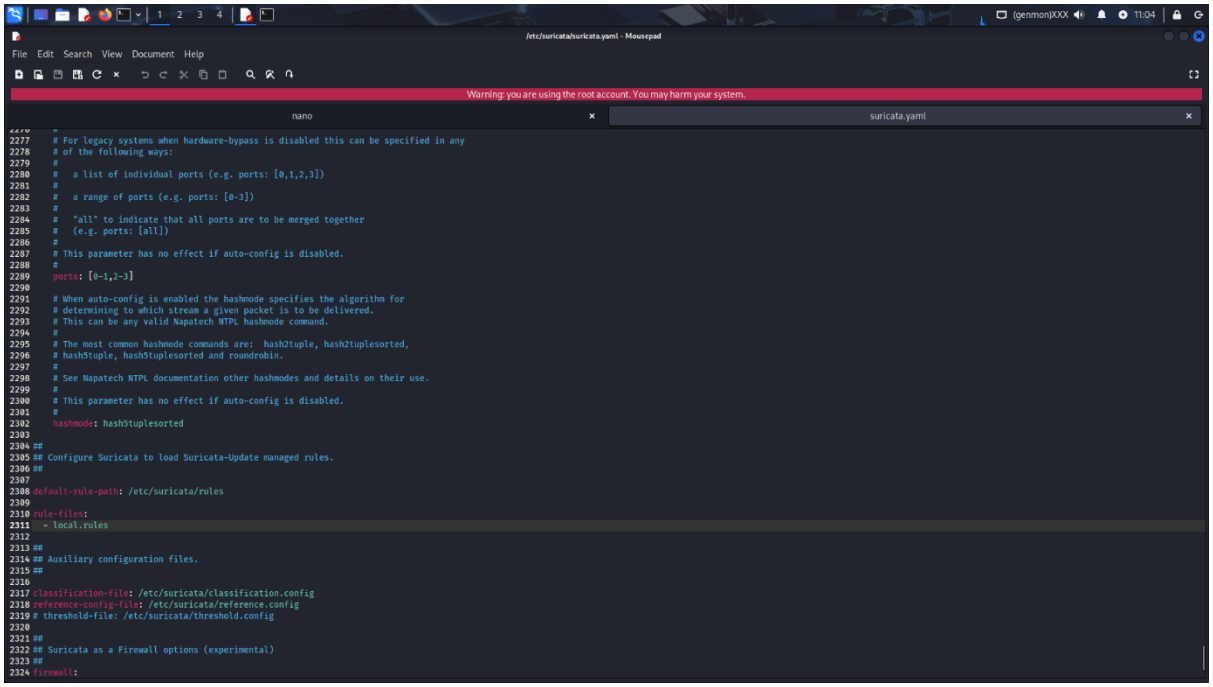
The objective of this task was to configure network-level detection and blocking mechanisms using Suricata IDS and CrowdSec to detect and mitigate malicious IP communication.

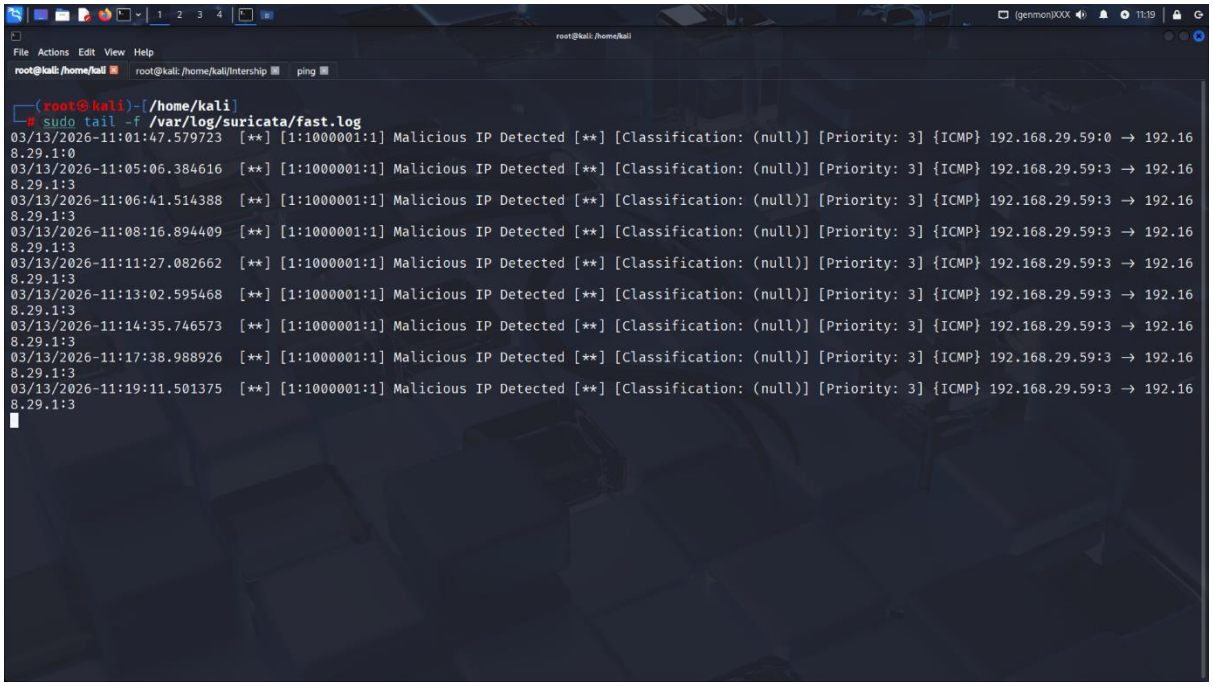
Suricata Configuration

A custom Suricata rule was created to detect traffic originating from a designated malicious IP address.



This rule generates an alert whenever traffic from the specified IP address is detected.


/etc/suricata/suricata.yaml - Mousepad
File Edit Search View Document Help
Warning: you are using the root account. You may harm your system.
nano
suricata.yaml
For legacy systems when hardware-bypass is disabled this can be specified in any
of the following ways:
#
a list of individual ports (e.g. ports: [0,1,2,3])
#
a range of ports (e.g. ports: [0-3])
#
"all" to indicate that all ports are to be merged together
(e.g. ports: [all])
#
This parameter has no effect if auto-config is disabled.
#
ports: [0-1,2-3]
When auto-config is enabled the hashmode specifies the algorithm for
determining to which stream a given packet is to be delivered.
This can be any valid Napatech NTPL hashmode command.
#
The most common hashmode commands are: hash2tuple, hash2tuplesorted,
hash5tuple, hash5tuplesorted and roundrobin.
#
See Napatech NTPL documentation other hashmodes and details on their use.
#
This parameter has no effect if auto-config is disabled.
#
hashmode: hash5tuplesorted
##
Configure Suricata to load Suricata-Update managed rules.
##
default-rule-path: /etc/suricata/rules
rule-files:
- local.rules
##
Auxiliary configuration files.
##
classification-file: /etc/suricata/classification.config
reference-config-file: /etc/suricata/reference.config
threshold-file: /etc/suricata/threshold.config
##
Suricata as a Firewall options (experimental)
##
firewall:


root@kali: /home/kali
File Actions Edit View Help
root@kali: /home/kali
root@kali: /home/kali/Intership
ping
┌──(root㉿kali)-[/home/kali]
└─# sudo tail -f /var/log/suricata/fast.log
03/13/2026-11:01:47.579723 [**] [1:1000001:1] Malicious IP Detected [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.29.59:0 → 192.168.29.1:0
03/13/2026-11:05:06.384616 [**] [1:1000001:1] Malicious IP Detected [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.29.59:3 → 192.168.29.1:3
03/13/2026-11:06:41.514388 [**] [1:1000001:1] Malicious IP Detected [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.29.59:3 → 192.168.29.1:3
03/13/2026-11:08:16.894409 [**] [1:1000001:1] Malicious IP Detected [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.29.59:3 → 192.168.29.1:3
03/13/2026-11:11:27.082662 [**] [1:1000001:1] Malicious IP Detected [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.29.59:3 → 192.168.29.1:3
03/13/2026-11:13:02.595468 [**] [1:1000001:1] Malicious IP Detected [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.29.59:3 → 192.168.29.1:3
03/13/2026-11:14:35.746573 [**] [1:1000001:1] Malicious IP Detected [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.29.59:3 → 192.168.29.1:3
03/13/2026-11:17:38.988926 [**] [1:1000001:1] Malicious IP Detected [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.29.59:3 → 192.168.29.1:3
03/13/2026-11:19:11.501375 [**] [1:1000001:1] Malicious IP Detected [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.29.59:3 → 192.168.29.1:3

MITRE ATT&CK Mapping

Alert	Tactic	Technique	Explanation
Malicious IP Detected	Command and Control	T1071	Suspicious network Communcation

Containment using CrowdSec

After detection, CrowdSec was used to block the malicious IP to prevent further communication attempts.

Command Used

cscli decisions add --ip 192.168.29.59

6.Risk Assessment Practice

Objective

The objective of this task was to perform a quantitative risk assessment using the Annualized Loss Expectancy (ALE) formula and evaluate risk severity using a 5x5 risk matrix.

ALE Calculation

Annualized Loss Expectancy (ALE) is calculated using the formula:

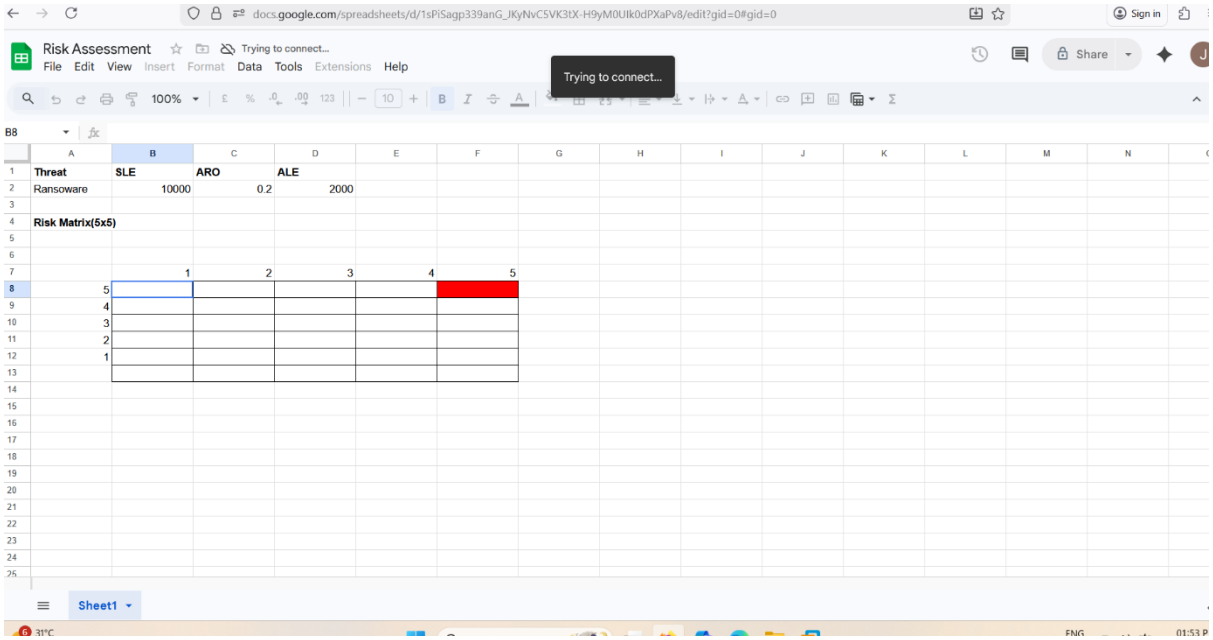
ALE = Single Loss Expectancy (SLE) × Annual Rate of Occurrence (ARO)

Example Scenario

- Threat: Ransomware
- SLE = $10,000
- ARO = 0.2

Calculation:

ALE = 10,000 × 0.2 = $2,000



Risk Matrix

A 5x5 risk matrix was created to evaluate the likelihood and impact of ransomware attacks.

Risk Interpretation

Based on the quantitative calculation and risk matrix analysis, ransomware represents a high-risk threat due to its significant financial and operational impact. This assessment highlights the importance of implementing preventive controls such as backups, monitoring, and patch management.

7. Incident Response Report

Objective

A simulated phishing incident was conducted in a controlled lab environment to evaluate detection and response capabilities. The attack involved PowerShell command execution triggered via a simulated phishing payload. Detection mechanisms identified suspicious activity, and containment measures were implemented to prevent further compromise. The exercise demonstrated the importance of structured incident response procedures and proactive monitoring.

Incident Timeline

Time	Event
10:00 AM	Phishing payload executed
10:02 AM	PowerShell process
10:05 AM	Alert triggered in SIEM
10:10 AM	Malicious IP blocked
10:20 AM	System restored and monitored

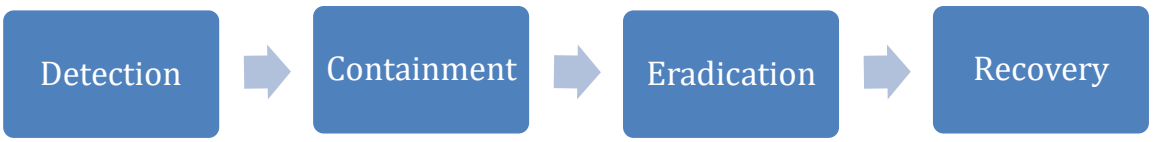
Technical Findings

The incident involved suspicious PowerShell execution mapped to MITRE ATT&CK technique T1059. Log analysis confirmed process creation events (Event ID 4688). Network monitoring tools detected outbound communication associated with the simulated attack.

Containment and Mitigation Steps

Action	Description
IP Blocking	Malicious IP blocked using CrowdSec
Log Monitoring	SIEM monitoring enabled
Service Hardening	Unnecessary services disabled
Backup Verification	System restore capability confirmed

Incident Response Flowchart



Incident Response Lifecycle Process

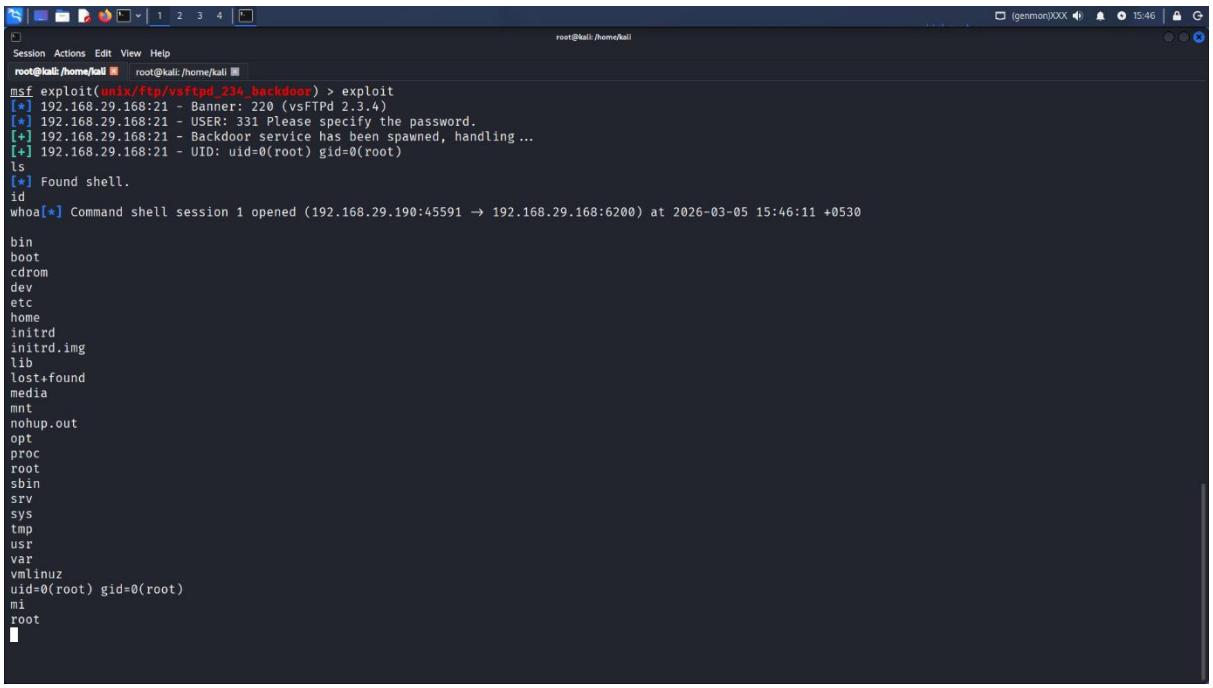
The incident response lifecycle follows a structured sequence starting with detection of suspicious activity, followed by containment to limit damage. The eradication phase removes malicious components, and recovery restores systems to normal operation while strengthening preventive controls.

8.Capstone Project – Full Incident Response Cycle

Objective

The objective of the capstone project was to simulate a full attack lifecycle in a controlled lab environment, detect the malicious activity, implement containment measures, and document findings aligned with the MITRE ATT&CK framework.

Attack Simulation using Metasploit



The exploit successfully established a remote shell session on the target machine.

Detection Phase

The exploitation attempt generated suspicious activity that was detected using monitoring tools. Network alerts and log analysis confirmed abnormal communication from the attacker IP.

Timestamp	Source IP	Alert Description	MITRE Technique
2016-03-05 15:46:11	192.168.29.59	VSFTPD Exploit Attempt	T1190

Final Incident Summary (200 Words – Important)

The capstone project successfully demonstrated a full incident response lifecycle within a controlled lab environment. An exploitation attempt was conducted using Metasploit against a vulnerable FTP service. The attack activity was detected through log monitoring and mapped to MITRE ATT&CK technique T1190 (Exploiting Public-Facing Application). Upon detection, containment measures were implemented by blocking the attacker IP using CrowdSec. The system was monitored to ensure no further malicious activity occurred. This exercise highlighted the importance of layered security controls, proactive detection mechanisms, and structured incident documentation. By integrating exploitation, detection, and containment processes, the organization can significantly reduce response time and minimize operational impact during real-world incidents.